

ISO/IEC 42001:2023 Gap Analysis

Statement of Applicability and Remediation Roadmap

Version	1.0
Date	2026-05-06
Author	Jay Wingard
Subject System	Genesis Autonomous AI Agent
Classification	Public

Document History

Version / Date	Author	Description
1.0 (2026-05-06)	Jay Wingard	Initial release

Contents

1	ISO/IEC 42001:2023 Gap Analysis: Genesis Autonomous AI Agent	2
1.1	1. Executive Summary	2
1.1.1	1.1.1 Assessment Methodology	2
1.2	2. Context: Mapping ISO 42001 to a Single-Operator System	3
1.3	3. Statement of Applicability	3
1.3.1	1.3.1 A.2-Policies Related to AI	3
1.3.2	1.3.2 A.3-Internal Organisation	4
1.3.3	1.3.3 A.4-Resources for AI Systems	5
1.3.4	1.3.4 A.5-Assessing Impacts of AI Systems	5
1.3.5	1.3.5 A.6-AI System Life Cycle	6
1.3.6	1.3.6 A.7-Data for AI Systems	7
1.3.7	1.3.7 A.8-Information for Interested Parties	8
1.3.8	1.3.8 A.9-Use of AI Systems	9
1.3.9	1.3.9 A.10-Third-Party and Customer Relationships	9
1.4	4. Gap Summary	10
1.4.1	1.4.1 By Severity	10
1.4.2	1.4.2 By Domain	11
1.5	5. Remediation Roadmap	11
1.5.1	1.5.1 Phase 1: Documentation (no architectural changes required)	11
1.5.2	1.5.2 Phase 2: External-facing controls (requires design decisions)	11
1.5.3	1.5.3 Phase 3: Measurement and formalization (requires development work)	12
1.6	6. Framework Adaptation Notes	12

ISO/IEC 42001:2023 Gap Analysis: Genesis Autonomous AI Agent

Version: 1.0 | Date: 2026-05-06 | Classification: Public

1. Executive Summary

This document presents a gap analysis of the Genesis autonomous AI agent system against ISO/IEC 42001:2023, the international standard for Artificial Intelligence Management Systems (AIMS). The analysis follows the Statement of Applicability (SoA) format: all 38 Annex A controls across 9 domains (A.2 through A.10) are assessed for applicability, and applicable controls are rated for current implementation status.

ISO 42001 was designed for organizations managing AI systems within institutional structures. Genesis is a single-tenant autonomous agent operated by one person. Many controls assume organizational governance bodies (boards, committees, audit functions) that do not exist in a solo-operated deployment. Where a control's intent applies but its institutional mechanism does not, this analysis identifies what functional equivalent exists in Genesis and whether it meets the control objective.

This assessment works from publicly available secondary sources for the Annex A control descriptions and objectives (gabriel.hk, isms.online, Advisera AIGL guides), not from the ISO 42001 normative text directly. The assessment is framed against control objectives rather than verbatim normative requirements.

The system description (D0) provides the factual foundation for this assessment.

Assessment Methodology

Each Annex A control is assessed using the following ratings:

- **Implemented:** The control objective is met through existing mechanisms
- **Partially Implemented:** The control objective is partially met; specific gaps are identified
- **Not Implemented:** The control objective is not met
- **Not Applicable:** The control does not apply to this deployment context (with justification)

Gap severity is rated as: - **Observation:** Minor process improvement opportunity - **Minor:** Gap with low risk in current deployment context - **Major:** Gap with material governance risk - **Critical:** Gap that would prevent certification or represents a significant unmitigated risk

2. Context: Mapping ISO 42001 to a Single-Operator System

ISO 42001 clauses 4 through 10 define the management system requirements. Before assessing individual controls, the following maps how the clause structure applies (and does not apply) to Genesis.

Clause 4 (Context of the Organization): Requires understanding the organization's context, stakeholder needs, and AIMS scope. For Genesis, the "organization" is one person. The scope is one system. Stakeholder needs collapse to the operator's needs plus the indirect interests of people affected by Genesis's external actions.

Clause 5 (Leadership): Requires management commitment and policy. In a single-operator system, the operator is both management and practitioner. Leadership commitment is demonstrated by the existence and design of the governance architecture itself.

Clause 6 (Planning): Requires risk assessment, impact assessment, and treatment planning. The risk assessment function maps to the action classification system and the NIST assessment (D1). Impact assessment maps to the stakeholder analysis in the system description (D0).

Clause 7 (Support): Requires resources, competence, awareness, communication, and documented information. Resources are the operator's time, compute, and API budgets. Competence is demonstrated through system design and operation.

Clause 8 (Operation): Requires operational planning and control, risk assessment, and risk treatment. Maps to the day-to-day operation of the autonomy model, approval gates, and monitoring systems.

Clause 9 (Performance Evaluation): Requires monitoring, internal audit, and management review. Monitoring maps to the Guardian/Sentinel architecture. Internal audit and management review do not have direct equivalents.

Clause 10 (Improvement): Requires nonconformity management and continuous improvement. Maps to the correction mechanism and the learning pipeline.

3. Statement of Applicability

A.2-Policies Related to AI

A.2.2-AI Policy

Applicability: Applicable Status: **Partially Implemented** Gap Severity: Minor

Genesis does not have a formal AI policy document. The functional equivalent is distributed across several mechanisms: steering rules (user-defined behavioral constraints), the system prompt (identity, drives, hard constraints), and the autonomy model configuration. These collectively define the system's approach to responsible operation, but they are not consolidated into a single policy artifact.

Evidence: Steering rules (STEERING.md), system identity (SOUL.md, USER.md), hard constraints in system prompt, autonomy configuration (config/autonomy.yaml).

Gap: No consolidated AI policy document. The intent is distributed across configuration files and prompt content. A consolidated policy would improve traceability and review ability.

A.2.3-Alignment with Other Organisational Policies

Applicability: Limited Status: **Not Applicable**

In a single-operator system without institutional policy frameworks (HR, legal, corporate governance), there are no other organizational policies to align with. The system's behavioral constraints are self-consistent by design.

A.2.4-Review of the AI Policy

Applicability: Applicable Status: **Not Implemented** Gap Severity: Minor

No scheduled review process exists for steering rules or system behavioral configuration. Changes occur reactively in response to incidents or observed behavioral drift. The NIST assessment (D1, GOV-1.4) identified the same gap.

A.3-Internal Organisation

A.3.2-AI Roles and Responsibilities

Applicability: Applicable (with adaptation) Status: **Implemented**

In the Genesis model, roles are divided between the human operator and the system. The operator holds authority over strategic direction, approval decisions, autonomy level management, and behavioral constraints. The system holds responsibility for execution, monitoring, and proposal generation within its approved autonomy level. This division is documented in the system description (D0, Section 3) and enforced through the autonomy model's type system (`src/genesis/autonomy/types.py` defines the 4-level hierarchy and action classification taxonomy).

Evidence: System description stakeholder analysis, autonomy level definitions (`src/genesis/autonomy/types.py`), approval lifecycle documentation.

A.3.3-Reporting of Concerns

Applicability: Applicable (with adaptation) Status: **Partially Implemented** Gap Severity: Observation

The system reports operational concerns to the operator through the event bus, Guardian alerts, and Sentinel alarms. The correction mechanism allows the operator to flag behavioral concerns. No mechanism exists for external parties (outreach recipients, people referenced in memory) to report concerns about the system's behavior.

Gap: No external reporting channel. For a personal-use system with limited external impact, this is an observation rather than a material gap.

A.4-Resources for AI Systems

A.4.2-Resource Documentation: Partially Implemented (Observation). Bootstrap manifest tracks subsystem capabilities. No consolidated resource inventory mapping compute, storage, API access, and personnel to lifecycle stages.

A.4.3-Data Resources: Partially Implemented (Minor). D0 Section 6 documents data categories. 12,164 memories, 6,175 observations, 998 session transcripts-sources are identifiable but no formal data catalog exists documenting legal basis for each collection channel.

A.4.4-Tooling Resources: Implemented. Dependency files (`requirements.txt`, `package.json`), tool registry, and MCP server configuration document the stack.

A.4.5-System and Computing Resources: Implemented. Container specs, VM config, Qdrant, SQLite, network topology, provider API configurations all documented.

A.4.6-Human Resources: Not Applicable. Single operator; competence demonstrated through system design.

A.5-Assessing Impacts of AI Systems

A.5.2-AI System Impact Assessment Process

Applicability: Applicable Status: **Partially Implemented** Gap Severity: Major

No formal impact assessment process exists. The action classification system (REVERSIBLE / COSTLY_REVERSIBLE / IRREVERSIBLE) implicitly assesses action-level impact, and the NIST assessment (D1) identifies impact categories. But a systematic assessment of potential harms across all system capabilities-the “what could go wrong” analysis-has not been performed as a standalone exercise.

Gap: No formal impact assessment. The NIST and EU AI Act assessments (D1, D3) partially fill this gap, but a dedicated impact assessment examining foreseeable misuse, failure modes, and harm scenarios would strengthen the governance posture.

A.5.3-Documentation of AI Impact Assessment

Applicability: Applicable Status: **Partially Implemented** Gap Severity: Major

Impact analysis is distributed across this assessment series (D0 through D3) rather than consolidated in a dedicated impact assessment document. The system description (D0) identifies stakeholders and potential impact categories. The NIST assessment (D1) characterizes risks.

Gap: No consolidated impact assessment document. Information exists but is distributed.

A.5.4-Assessing AI System Impact on Individuals or Groups

Applicability: Applicable Status: **Partially Implemented** Gap Severity: Minor

The system description identifies external message recipients as the primary group of affected individuals (D0, Section 3.2). The EU AI Act assessment (D3) analyzes

transparency obligations. Individual-level impact assessment (what happens if the system sends an inappropriate message to a specific person, contacts the wrong person, or acts on incorrect information about someone) is addressed qualitatively but not systematically.

A.5.5-Assessing Societal Impacts of AI Systems

Applicability: Limited Status: **Partially Implemented** Gap Severity: Observation

A single-user personal agent has limited societal impact. The most significant societal consideration is the system's use of LLM providers and the energy consumption associated with inference workloads. This is acknowledged but not quantified. If the system were replicated at scale (as an open-source project that others deploy), societal impact assessment would become material.

A.6-AI System Life Cycle

A.6.1.2-Objectives for Responsible Development of AI Systems

Applicability: Applicable Status: **Implemented**

Responsible development objectives are documented in the project instructions (CLAUDE.md), design principles, and system identity documents. These include: user sovereignty as absolute, honesty over comfort, action over analysis paralysis, simplicity as strength, and specific hard constraints (no unsanctioned financial transactions, no silent timeouts, no modification of learning systems without user awareness).

Evidence: CLAUDE.md design principles section, SOUL.md hard constraints, system prompt behavioral guidelines.

A.6.1.3-Processes for Responsible AI System Design and Development

Applicability: Applicable Status: **Implemented**

Development follows documented processes: PR-based workflow with code review, test requirements before commit, worktree isolation for feature work, continuous integration. The genesis-development skill defines development procedures.

A.6.2.2-AI System Requirements and Specification

Applicability: Applicable Status: **Partially Implemented** Gap Severity: Observation

System requirements are expressed through design documents, architecture documentation, and the system prompt rather than a formal requirements specification. The system's behavioral requirements are defined through steering rules and hard constraints. No requirements traceability matrix exists.

A.6.2.3-Documentation of Design and Development: Implemented. Architecture docs (docs/architecture/), codebase comments, commit messages, PR descriptions. D0 provides the governance-oriented view.

A.6.2.4-Verification and Validation: Partially Implemented (Minor). Test suite covers functional correctness. The correction mechanism (877 successes,

4 corrections in background_cognitive) provides ongoing behavioral validation. No formal V&V covers trustworthiness properties (safety, fairness, transparency) specifically.

A.6.2.5-Deployment: Implemented. Systemd service config, bootstrap scripts, health checks, monitoring.

A.6.2.6-Operation and Monitoring: Implemented. This is the system's strongest governance area. Guardian (src/genesis/guardian/) performs health checks, Sentinel (src/genesis/sentinel/) handles alarm response, event bus (src/genesis/observab captures 135,843 structured events, and the dashboard provides the operator interface. All running continuously for 58 days.

A.6.2.7-Technical Documentation: Partially Implemented (Observation). Developer documentation exists. Governance documentation is this assessment series. No traditional user manual (the operator built the system).

A.6.2.8-Recording of Event Logs: Implemented. The event bus records all significant system events with structured metadata. Approval records capture the full approval lifecycle (107 requests with resolution attribution). Session transcripts record all LLM interactions. Git history tracks all code changes.

A.7-Data for AI Systems

A.7.2-Data for Development and Enhancement of AI Systems

Applicability: Applicable (with adaptation) Status: **Partially Implemented** Gap Severity: Minor

Genesis does not train its own models. Its "data for development" consists of the operator's conversations, ingested knowledge, and behavioral corrections that shape system behavior through the memory and learning systems. These data management processes are partially documented but not formalized.

The adaptation point: ISO 42001 assumes the organization is training or fine-tuning models. Genesis uses pre-trained models via API and adapts behavior through prompt engineering, memory, and configuration rather than model training. The data governance concern is different: it is about the quality and accuracy of stored memories and knowledge, not about training data representativeness.

A.7.3-Acquisition of Data

Applicability: Applicable Status: **Partially Implemented** Gap Severity: Minor

Data is acquired from multiple sources: user conversations (consent implicit in use), web fetches (public data), email monitoring (operator's own accounts), ingested documents (user-directed). Legal basis for collection is generally sound (personal use, operator consent, public data). No formal documentation of data sources and their legal basis exists.

A.7.4-Quality of Data for AI Systems

Applicability: Applicable Status: **Partially Implemented** Gap Severity: Minor

Memory verification procedures require the system to check recalled information against current state before acting. The knowledge ingestion pipeline applies

credibility scoring. No formal data quality metrics are defined or tracked.

Gap: Data quality is addressed procedurally (verify before acting) but not measured quantitatively.

A.7.5-Data Provenance

Applicability: Applicable Status: **Partially Implemented** Gap Severity: Observation

Knowledge units include ingestion source metadata. Memory entries include source attribution. Session transcripts provide full provenance for conversation-derived data. The knowledge pipeline tracks provenance through the ingestion process. No formal data lineage documentation exists as a standalone artifact.

A.7.6-Data Preparation

Applicability: Limited Status: **Not Applicable**

Genesis does not prepare training datasets. Data preparation consists of the knowledge distillation pipeline (extracting key concepts from ingested sources), which is documented in the pipeline code.

A.8-Information for Interested Parties

A.8.2-System Documentation and Information for Users

Applicability: Applicable (with adaptation) Status: **Implemented**

The “user” is the operator who built the system. System documentation exists at multiple levels: architecture docs, code comments, README, CLAUDE.md, and this assessment series. The operator has direct access to all system internals, making traditional “user documentation” redundant.

A.8.3-External Reporting

Applicability: Applicable Status: **Not Implemented** Gap Severity: Major

No channel exists for external parties to report problems with the system. If Genesis sends an inappropriate message or takes an action that affects someone, that person has no way to contact the operator through the system, identify that an AI system was involved, or request remediation.

For a personal-use system with limited outreach activity, this is a lower-priority gap than for a customer-facing product. It becomes a material gap if outreach volume increases or if the system interacts with people who do not have a pre-existing relationship with the operator.

Gap: No external reporting mechanism. The open-source repository provides a theoretical path (GitHub issues), but affected individuals would not know to look there and it is not designed for that purpose.

A.8.4-Communication of Incidents

Applicability: Applicable Status: **Not Implemented** Gap Severity: Major

No plan exists for communicating AI failures or harmful actions to affected parties. Internal incident detection is well-implemented (Guardian, Sentinel, event bus),

but there is no process for determining when an incident should be communicated externally, to whom, or how. The NIST assessment (D1, MANAGE-4.3) identified the same gap.

A.8.5-Information for Interested Parties

Applicability: Applicable Status: **Partially Implemented** Gap Severity: Minor

The open-source Genesis codebase provides transparency about system capabilities and design. This assessment series provides governance-oriented documentation. No proactive disclosure to regulators or partners is required in the current deployment context (personal use, no regulatory mandate).

A.9-Use of AI Systems

A.9.2-Processes for Responsible Use of AI Systems

Applicability: Applicable Status: **Implemented**

Responsible use processes are embedded in the system architecture: the autonomy model (`src/genesis/autonomy/`) gates what the system can do at each trust level, the approval pipeline requires human authorization for high-consequence actions, steering rules constrain behavior, and the correction mechanism adapts behavior based on operator feedback. These are not documented as a separate “responsible use protocol” but they constitute one.

Evidence: Autonomy subsystem (`src/genesis/autonomy/`), approval lifecycle, steering rules (`STEERING.md`), correction mechanism.

A.9.3-Objectives for Responsible Use

Applicability: Applicable Status: **Implemented**

Responsible use objectives are documented in the system identity: user sovereignty is absolute, no unsanctioned financial transactions, no silent timeouts, no withholding information to manipulate decisions, no claiming certainty without evidence.

A.9.4-Intended Use of the AI System

Applicability: Applicable Status: **Partially Implemented** Gap Severity: Observation

The system’s intended use (personal cognitive partner) is defined in the system description and identity documents. No formal mechanism prevents scope creep beyond the intended use. The steering rules can constrain behavior but depend on the operator recognizing and addressing scope creep. This is primarily an operator discipline concern rather than a technical gap.

A.10-Third-Party and Customer Relationships

A.10.2-Allocating Responsibilities

Applicability: Applicable Status: **Not Implemented** Gap Severity: Major

No formal responsibility allocation exists between the Genesis operator and LLM providers. The NIST assessment (D1, GOV-6.1) identified this as the system's most significant governance gap. Provider terms of service define their responsibilities unilaterally; the operator has not assessed whether those terms adequately address Genesis's specific risk profile.

Gap: No documented responsibility allocation for AI component supply chain. This is particularly relevant given the volume and sensitivity of data transmitted to LLM providers.

A.10.3-Suppliers

Applicability: Applicable Status: **Not Implemented** Gap Severity: Major

LLM providers are suppliers of a critical system component (inference capability). No supplier assessment has been performed. No contractual protections address Genesis-specific risks (data retention of operational context, model version change notification, incident response for provider-side breaches).

Gap: Supplier governance for LLM providers does not exist. The system depends entirely on provider self-governance.

A.10.4-Customers

Applicability: Not Applicable

Genesis does not have customers. It serves one operator. If the open-source code-base is deployed by other users, those deployments are out of scope for this assessment.

4. Gap Summary

By Severity

Critical: None identified. No gap represents an immediate, unmitigated danger.

Major (5 gaps): 1. **A.5.2/A.5.3-Impact assessment:** No formal impact assessment process or document 2. **A.8.3-External reporting:** No channel for affected parties to report problems 3. **A.8.4-Incident communication:** No plan for communicating incidents to affected parties 4. **A.10.2-Responsibility allocation:** No formal responsibility allocation with LLM providers 5. **A.10.3-Supplier governance:** No supplier assessment or contractual protections for LLM providers

Minor (8 gaps): 1. A.2.2-No consolidated AI policy document 2. A.2.4-No policy review schedule 3. A.4.3-No formal data catalog 4. A.5.4-Individual impact assessment is qualitative, not systematic 5. A.6.2.4-No trustworthiness-specific V&V 6. A.7.2-Memory/knowledge data management not formalized 7. A.7.3-No formal documentation of data source legal basis 8. A.7.4-No quantitative data quality metrics

Observation (7 gaps): 1. A.3.3-No external concern reporting mechanism 2. A.4.2-No consolidated resource inventory 3. A.5.5-Societal impact not quantified 4. A.6.2.2-No formal requirements specification 5. A.6.2.7-Technical documen-

tation exists but not governance-targeted 6. A.7.5-No standalone data lineage documentation 7. A.9.4-No formal scope creep prevention mechanism

By Domain

Domain	Controls	Implemented	Partial	Not Impl.	N/A
A.2 Policies	3	0	1	1	1
A.3 Internal Organisation	2	1	1	0	0
A.4 Resources	5	2	2	0	1
A.5 Impact Assessment	4	0	4	0	0
A.6 AI Lifecycle	9	5	3	0	1
A.7 Data	5	0	4	0	1
A.8 Information	4	1	1	2	0
A.9 Use	3	2	1	0	0
A.10 Third-Party	3	0	0	2	1
Total	38	11	17	5	5

Implementation rate: 11 of 33 applicable controls fully implemented (33%). 17 partially implemented (52%). 5 not implemented (15%).

The strongest domains are A.6 (AI System Life Cycle, 5 of 8 applicable controls implemented) and A.9 (Use of AI Systems, 2 of 3 implemented). The weakest domains are A.10 (Third-Party Relationships, 0 of 2 applicable controls implemented) and A.8 (Information for Interested Parties, 1 of 4 implemented).

5. Remediation Roadmap

Phase 1: Documentation (no architectural changes required)

Target: address Major gaps 1, 4, and 5 plus Minor gaps 1 and 2

1. Write a consolidated AI policy document referencing existing steering rules, hard constraints, and design principles (A.2.2, A.2.4)
2. Document a formal impact assessment covering foreseeable harm scenarios for each category of external action (A.5.2, A.5.3)
3. Document LLM provider data handling practices and terms of service (A.10.2, A.10.3)
4. Assess whether provider terms adequately cover Genesis's data transmission profile (A.10.3)
5. Establish a review schedule (quarterly) for the AI policy, steering rules, and autonomy levels (A.2.4)

Phase 2: External-facing controls (requires design decisions)

Target: address Major gaps 2 and 3

6. Design and implement an external reporting channel (A.8.3). Options range from a contact email in outreach messages to a dedicated incident reporting form.
7. Define an incident communication procedure specifying: what constitutes a reportable incident, who should be notified, what information should be provided, and within what timeframe (A.8.4)
8. Implement outreach attribution (include system identification in external communications to meet transparency expectations) (A.8.5)

Phase 3: Measurement and formalization (requires development work)

Target: address Minor gaps 3-8

9. Create a data catalog documenting all data sources, types, and legal basis (A.4.3, A.7.3)
 10. Define quantitative data quality metrics for the memory and knowledge systems (A.7.4)
 11. Implement trustworthiness-specific validation tests (A.6.2.4)
 12. Formalize memory and knowledge data management processes (A.7.2)
-

6. Framework Adaptation Notes

Several observations about ISO 42001's applicability to autonomous agent systems:

The organizational assumption: ISO 42001 assumes an organization with institutional structures—management layers, governance committees, audit functions, segregation of duties. A single-operator system cannot implement these controls as designed, but their underlying intent (accountability, review, independent verification) can be partially addressed through the system's own governance architecture (the two-ego model provides a limited form of proposal-review separation, the correction mechanism provides behavioral accountability).

The training data assumption: The data controls (A.7) assume the organization is training or fine-tuning AI models. Systems that use pre-trained models via API present a different data governance challenge: the concern is not training data quality but operational data quality (the accuracy and relevance of stored memories and knowledge that shape system behavior).

The external impact surface: ISO 42001's information controls (A.8) are designed for products and services with identifiable users or customers. An autonomous agent acting on behalf of an operator presents a different disclosure challenge: the affected parties may not know an AI system is involved, may have no relationship with the system or its operator, and may have no channel through which to raise concerns. This is the area where autonomous agents present governance challenges that ISO 42001 does not fully address.

Supplier governance for API-based AI: The third-party controls (A.10) assume suppliers that can be contractually bound and audited. LLM providers offer API access under standard terms of service with no negotiation, no audit rights, and

no Genesis-specific protections. The power asymmetry between a single-operator system and major AI providers means traditional supplier governance mechanisms do not apply. The operator's primary lever is provider selection and diversification (the circuit breaker pattern), not contractual negotiation.

These observations are developed further in the methodology document (D4).